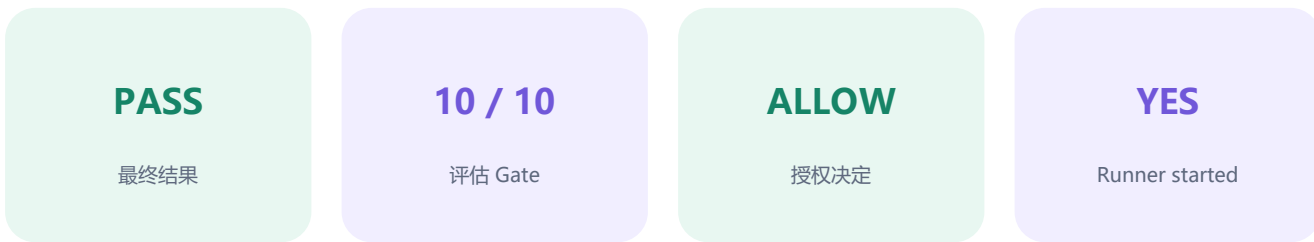


P3 Resource Capsule

真实端到端测试报告

真实 ModelArk response · Docker Container Runtime · Read-only Resource Capsule ·
Decision Receipt



本次 PASS 覆盖的正常授权数据路径 (ALLOW path)

测试编号	P3-RC-E2E-20260830-01
测试时间	2026-08-30 15:22 (Asia/Shanghai)
目标 Commit	9540a5abef797aefdbccb98577854f663fa1514c
核心结论	授权、容器启动、资源读取、模型回答、Receipt 与资源完整性全部通过

结论边界：本报告证明正常授权 ALLOW path；未授权、撤销、路径逃逸与主动写入仍需单独负向测试。

1. 执行摘要

本报告记录了一次成功的 P3 Resource Capsule **真实模型端到端 ALLOW 路径测试**。测试使用生产构建后的 Web/API、本地 Docker Container Runtime、真实 ModelArk 模型配置，以及服务端管理的 `orders-incident` 冻结测试资源；不是 HTTP mock，也不是预先写死的模型答案。

操作者以 `user-a` (Demo User A) 身份，为一次 `P3 Incident Analyst` Run 显式选择并委托了其有权使用的 `orders-incident` Protected Resource。任务要求 Agent 给出事故编号、影响、根因、精确时间线、证据文件名和预防措施。Agent 返回的关键事实与三个资源文件完全一致，并明确列出了实际读取的文件。关联 Decision Receipt 显示：

- Decision: `allow`
- Resource: `orders-incident`
- Grant generation: `1`
- Runner started: `yes`

Run 完成后，对三个资源文件重新计算 SHA-256，结果与冻结的 `baseline-manifest.json` 完全一致，说明本次执行没有改变资源文件的任何字节。

总体结论：“用户显式选择 -> 服务端授权与路径校验 -> 只读挂载计划 -> Container Runner 启动 -> 模型读取获取批资源 -> 返回有证据的分析 -> 生成可审计 Receipt”这一整条正常授权链路已成功工作。

2. 测试目标



本次 PASS 覆盖的正常授权数据路径 (ALLOW path)

2.1 核心目标

验证一个拥有有效 Entitlement 的 Human Principal，能否把一个合格的 Protected Resource 显式委托给单次 Agent Run；并验证系统能否将该授权决定安全地转换成 Agent 容器可读取、不可修改的 Resource Capsule。

2.2 本次实际验证的属性

1. Resource 不会因为用户拥有 Entitlement 就自动暴露，必须在本次 Run 中显式选择。
2. 服务端能为正确的 Principal、Agent、Resource 和 Entitlement generation 生成 ALLOW 决定。
3. Runner 只在授权通过后启动。
4. 模型能读取只存在于获批 Resource 文件中的事实。
5. 模型能跨多个文件综合信息并引用准确文件名。
6. Run 结束后 Protected Resource 字节保持不变。
7. Receipt 能把 Run、Principal、Agent、Resource、授权代次和 Runner 启动状态关联起来。

2.3 本次单一 Live Run 没有覆盖的范围

以下负向场景没有在本次 Run 中执行，不能因为本报告 PASS 就推断它们也已通过：

- `user-a` 越权请求 `payments-incident`；
- Entitlement revoke 后再次请求；
- `local-process` Runtime 对 Capsule 的拒绝；
- 主动尝试写入只读挂载；
- symlink 或 `..` 路径逃逸；
- revoke/re-grant 与编译并发竞态；
- 网络隔离、通用工具限制和生产级身份认证。

3. 测试环境与版本

项目	记录值
Repository	Starlove-Butterfly-techjam-agent-middleware
Branch	main
Commit	9540a5abef797aefdbccb98577854f663fa1514c
Commit 摘要	Merge pull request #27 from Simon-Xu3/codex/final-submission-audit
生成报告前 worktree	clean
Node.js	v24.19.0
npm	11.17.0
启动入口	scripts/start-local-poc.sh
Web/API	production build
Runtime provider	Docker-backed container profile
Runtime image	volc-agent-runtime:local
应用地址	http://localhost:3100/
使用 3100 的原因	3000 已被不相关的 CS1010 WebTop 容器占用
Model service	BytePlus ModelArk, Asia Pacific (Johor)
操作者选择的模型	Dola-Seed-2.1-turbo, 260628
API Base URL	https://ark.ap-southeast.bytepluses.com/api/v3
Secret 处理	API Key 仅通过进程环境变量传入，本报告不记录其值

启动器检测到 Linux Runtime 中 Codex Landlock 不可用，因此在一次性的外层容器边界内回退为 `danger-full-access`。这是当前 POC 的预期兼容模式，不代表生产级 sandbox。测试没有把无关 host 目录挂载到 Agent Runtime。

4. 测试角色与关联标识

字段	值
Principal	user-a / Demo User A
Agent name	P3 Incident Analyst
Agent ID	3f878e87-717a-4f5f-b343-a2961fdbb9e8
Resource	orders-incident / Orders Incident
Run ID	1a5fdb9f-1a57-4069-9f9e-b30de20b0b49
Receipt ID	e52320b5-a38f-442a-bad7-3fd4d1902271
Grant generation	1

5. Agent 配置

Name

P3 Incident Analyst

Description

Analyzes delegated incident resources and produces evidence-backed reports.

Instructions

When a Run includes a Resource Capsule, inspect the single read-only directory available under /resources. Never modify its contents. Base conclusions only on the delegated files, cite exact filenames for every important claim, distinguish facts from inference, and explicitly state when evidence is insufficient.

这组指令要求 Agent 不只是进行通用问答，而是：发现获批挂载、读取多个来源、保持只读约束、区分事实与推断，并给出可核对的证据链。

6. 提交的任务与 Resource 委托

人工选择的 Resource

Orders Incident (orders-incident)

Task 原文

Investigate the delegated checkout incident using only the Resource Capsule.

Return:

- 1. The incident ID, impact, and UTC incident window.
- 2. The exact configuration mistake and affected service version.
- 3. A timeline from deployment to full recovery, including exact times.
- 4. An evidence table with columns: Claim, Evidence, Source filename.
- 5. Two concrete preventive actions.

Do not guess or modify any resource. End with a "Files consulted" list.

7. 冻结资源中的预期答案

预期事实	Ground truth 来源
Incident ID 为 INC-2026-0826-ORDERS	incident-report.md
Incident window 为 21:40-22:15 UTC	incident-report.md
18% checkout 请求返回 HTTP 500	incident-report.md
v2.14.0 在约 21:38 部署/启动	timeline.md、orders-service.log
数据库连接池启动大小为 5	orders-service.log
正确连接池大小为 50	incident-report.md、恢复日志
首次 pool wait warning 为 21:40:11	orders-service.log
首次 checkout timeout 为 21:40:19	orders-service.log
21:44 触发告警	timeline.md
22:05 确认根因	timeline.md
22:11/22:11:30 开始 rollback	timeline.md、orders-service.log
22:12:04 启动 v2.13.2, pool size 50	orders-service.log
22:15 错误率恢复到 0.1% 以下	orders-service.log

8. 实际模型输出与准确性

Agent 返回了任务要求的全部部分：

- 1. **事故身份与影响：** 正确给出 INC-2026-0826-ORDERS、18% HTTP 500、21:40-22:15 UTC，并正确计算为 35 分钟。
- 2. **根因：** 正确指出 DB_POOL_SIZE 被配置为 5 而不是 50，连接池容量减少 90%，受影响版本为 v2.14.0。
- 3. **时间线：** 包含 21:38:02 服务启动、21:40:11 pool wait warning、21:40:19 首次 checkout timeout、21:44 告警、21:52 on-call 被呼叫、22:05 定位根因、22:11:30 开始回滚、22:12:04 正常版本启动、22:15:00 错误率恢复。
- 4. **证据表：** 将结论关联到 incident-report.md、orders-service.log 和 timeline.md。

5. **预防措施：** 建议对关键配置增加部署前范围校验；采用 canary/progressive rollout，并在 5xx 异常升高时自动回滚。
6. **Files consulted：** 明确列出了 `/resources/orders-incident/` 下的三个文件。

准确性判定

要求	结果	说明
Incident identity	PASS	Incident ID 完全准确
Impact	PASS	准确返回 18% HTTP 500
Root cause	PASS	错误值 5 与正确值 50 均准确
Affected version	PASS	准确识别 v2.14.0
Timeline	PASS	关键节点与日志精确时间均覆盖
Multi-file synthesis	PASS	综合使用三个文件
Filename citations	PASS	引用了三个准确文件名
Recommendations	PASS	建议合理，且没有冒充 fixture 原始事实
Unsupported claims	PASS	未发现影响结论的虚构事实事实

一个轻微的措辞精度问题：回答把 21:38:02 描述为 deployment time。日志直接证明的是 v2.14.0 在 21:38:02 started，而 timeline 以分钟精度记录 21:38 deployment。该差异不影响根因、时间线判断和 PASS 结论。

9. Decision Receipt 证据

Receipt 字段	观察值	含义
Decision	allow	授权通过
UI status	Resource authorized	获批只读挂载跨过 Runtime seam
Run	1a5fdb9f-1a57-4069-9f9e-b30de20b0b49	稳定 Run 关联标识
Receipt	e52320b5-a38f-442a-bad7-3fd4d1902271	稳定审计记录标识
Principal	user-a	正确 demo identity
Agent	3f878e87-717a-4f5f-b343-a2961fdbb9e8	正确 Agent target
Resource	orders-incident	正确的显式委托
Grant generation	1	当前、正数授权代次
Runner started	yes	请求通过授权边界后 Runner 被调用
Created	2026-08-30T07:22:47.250Z	Receipt 创建时间

其中 Runner started: yes 非常关键：仅有一个正确的模型答案，可能来自其他路径或预先构造；而 Receipt、fixture 独有事实、准确文件名和 Runner start 组合起来，说明本次正常授权 Runtime 路径确实被执行。

10. Resource 完整性验证

Run 完成后重新计算三个文件的 SHA-256，并与冻结的 baseline-manifest.json 比较：

文件	Frozen SHA-256	Post-Run	结果
incident-report.md	ed5013e40e57e5b4bb22c039b6bc41ef3bf0f285c97077c41bc082555f393383	相同	PASS
orders-service.log	fb29cc9a0914a3abf7ddb5f76e33b51eb78a86e8e24579bf6269e41aab3b8db0	相同	PASS
timeline.md	cbadc58aa24eb1bb49025bdbc144665602607f65b346df45275842c647614dbd	相同	PASS

这证明本次完成的 Run 没有修改受保护 fixture 的字节。它能证明“本次执行结果未修改”，但不能完全替代一个专门的主动写入测试；后者还需要证明文件系统边界明确拒绝写操作。

11. 端到端成功门槛

Gate	必需证据	实际观察	结果
Application readiness	built server 在选定端口监听	127.0.0.1:3100	PASS
Browser/API connectivity	Session connected, 无浏览器错误	connected; 无 warning/error	PASS
Explicit delegation	本 Run 显式选择 Orders Incident	Receipt 为 <code>orders-incident</code>	PASS
Authorization	稳定 ALLOW decision	<code>allow</code>	PASS
Current Entitlement	正数 generation	1	PASS
Runtime boundary	Runner 仅在 ALLOW 后启动	<code>Runner started: yes</code>	PASS
Protected-data access	回答出现 fixture 独有事实	ID、比例、配置和时间均准确	PASS
Evidence discipline	引用准确文件名	三个文件全部列出	PASS
Read-only outcome	Resource 字节不变	三个 hash 匹配 baseline	PASS
Auditability	Run 与 Receipt 可关联	两个稳定 ID 均存在	PASS

最终结果：PASS（10/10 个已评估 Gate 全部通过）。

12. 为什么这不是普通的“聊天机器人回答成功”

- Task 本身没有提供 Incident ID、18%、pool size、版本号或精确时间。
 - Agent 返回了只存在于 Protected Resource 内的准确事实。
 - Agent 明确列出了其使用的三个文件。
 - Receipt 把 Principal、Agent、Resource、generation、Run、Receipt 和 Runner start 关联起来。
 - Run 后文件 hash 与冻结 baseline 完全一致。
- 因此，本次测试同时验证了正常授权场景下的 **control plane** (delegation、authorization、compilation、Receipt) 和 **data plane** (container mount、file inspection、model response) 。

13. 前端体验问题

测试最初看起来像“没有回复”，原因是 Playground 使用了内部滚动区域。生成的 Agent message 与 Receipt 位于 Task composer 上方，而 viewport 仍停留在靠近底部的位置。发送后 Resource selector 还会为下一次 Run 重置为 No Resource；该状态不代表刚完成的 Run 没有选择 Resource。

这是 UX 问题，不是执行失败。建议：

1. 新消息和 Receipt 到达时自动滚动到最新输出。
2. 显示 Run submitted -> Runner started -> Run completed 状态条。
3. 在已完成 Run 的 message card 内持续显示当次 Resource。
4. 当回复在内部 viewport 外时提供 Jump to latest response。
5. 提供 Answer + Decision Receipt 一键导出功能。

14. 建议的后续负向测试

P1: 未授权 Resource

用 user-a 请求 payments-incident，预期 HTTP 403、entitlement_missing、Runner started: no，且响应不泄露 host path。

P2: Revoke 后重试

撤销 orders-incident 后提交新 Run，预期在 Runner 之前返回 entitlement_revoked；同时此前 ALLOW Receipt 仍可审计。

P3: 主动写入只读挂载

让专用测试 Agent 尝试在 /resources/orders-incident 创建 marker 文件，预期文件系统拒绝写入，并再次验证三个 baseline hash。

P4: 不支持的 Runtime

以 RUNTIME_PROVIDER=local-process 启动 built server，再提交 Capsule Run，预期 runtime_profile_unsupported 且 Runner 不启动。

P5: 路径和竞态回归

在每次 security-core 修改后运行 symlink/.. escape、tampered decision、revoke/re-grant race 测试。

15. 可复现步骤摘要

1. 启动 Docker Desktop。
2. 私下 export ARK_API_KEY、ARK_MODEL 和 Johor ARK_BASE_URL，不得把 Key 放进截图或日志。
3. 选择新的 rehearsal state directory 和未占用的 host port。
4. 运行 `bash ./scripts/start-local-poc.sh`。
5. 打开终端显示的 localhost URL。

6. 按第 5 节配置 Agent。
7. 选择 Demo User A，粘贴第 6 节 Task，并显式选择 Orders Incident。
8. 按第 7 节核对答案，按第 9 节核对 Receipt。
9. 重新计算三个 fixture hash，与 `baseline-manifest.json` 比较。

16. 证据处理与限制

- 本报告不包含 API Key。
- 可分享证据中不记录绝对 host path。
- Incident 数据均为 fictional demo fixture，不是真实客户数据。
- 当前 identity 为 demo-grade，不能宣传为生产身份认证。
- 外层 container fallback 是 POC 隔离，不证明网络或通用工具被完全限制。
- Revocation 是 prospective，不会热卸载正在运行的 Run，也不会消除模型线程已经保留的知识。

17. 签署结论

P3 Live ALLOW path 状态： 可以用于团队演示，但必须同时说明本报告记录的边界和仍需执行的负向测试。

对外简述： 本次测试通过真实本地 Container Runtime 和真实 ModelArk response 执行了授权 Resource Capsule 路径。Agent 准确综合了所有获批文件；关联 Receipt 记录了 ALLOW 与 Runner start；Run 后 fixture hash 与冻结 baseline 完全一致。